3. Authentication & Authorization — Ajaia Docs

1. What is the difference?

Authentication (AuthN)	Authorization (AuthZ)
Who are you?	What can you access?
Identifies Alice or Bob	Checks Owner, Editor or Viewer
Uses session cookies	Uses database ownership and sharing records
Returns 401 if unauthenticated	Returns 403 or 404 if unauthorized

2. What options do we have?

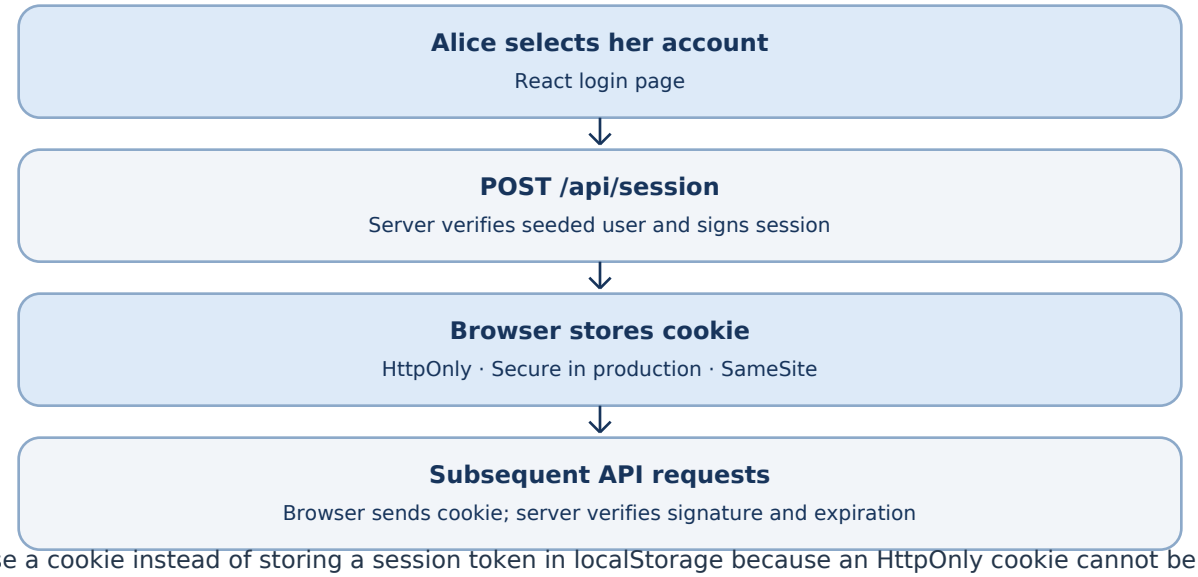
Option	Pros	Cons
Seeded users + signed cookie	Fast, easy for reviewers to test	No real identity verification
Auth.js / OAuth	Real authentication, production-ready foundation	Provider configuration and callback setup
Clerk / Auth0	Managed login and sessions	External dependency and setup
Custom JWT login	Flexible	Must securely implement password and token management

My choice: Seeded users (Alice, Bob, Carol) with an HMAC-signed session cookie.

Why? The assessment explicitly allows mocked authentication. I prioritize working document sharing over building a login system.

A signed cookie prevents undetected tampering with the selected identity, but anyone can still choose any seeded user. This is demo-only authentication.

3. How does a session work?



I use a cookie instead of storing a session token in localStorage because an HttpOnly cookie cannot be read directly by JavaScript.

Tradeoff: Cookies are automatically sent with matching requests, so state-changing endpoints also need appropriate CSRF defenses.

4. How does authorization work?

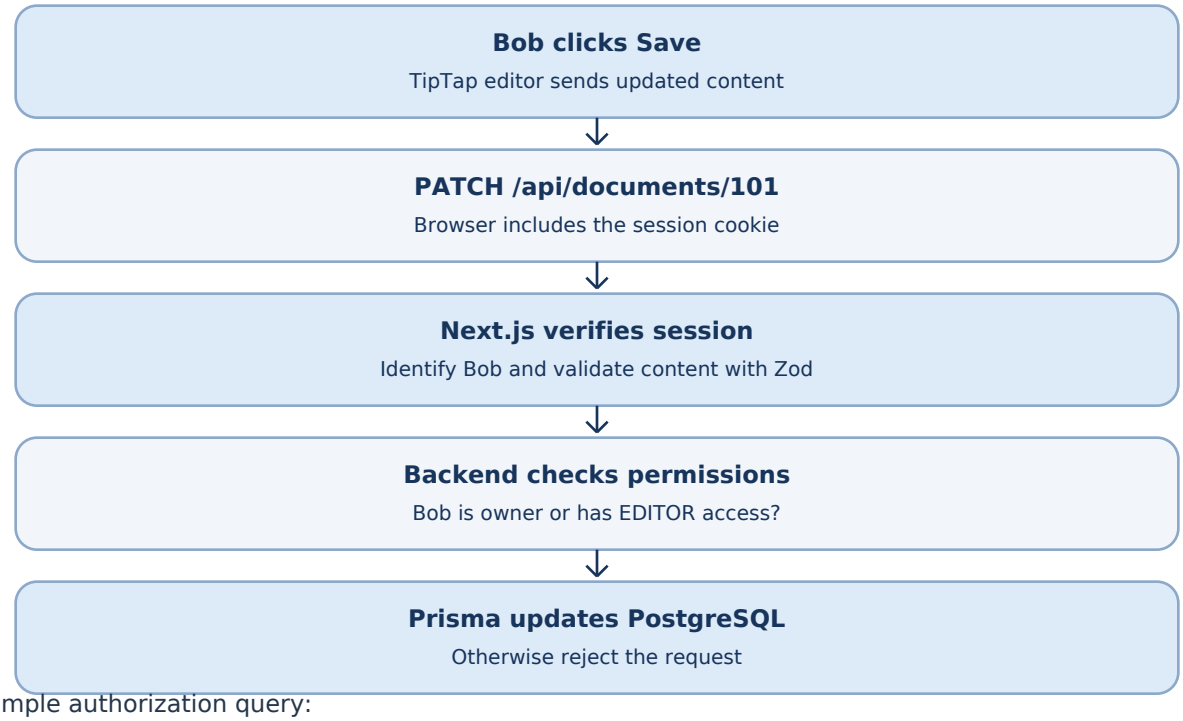
My database has documents.owner_id (owner), document_shares.user_id (invited user), and document_shares.role (VIEWER or EDITOR).



Action	Owner	Editor	Viewer	Outsider
Read	Allow	Allow	Allow	404
Edit / rename	Allow	Allow	403	404
Share / unshare	Allow	403	403	404
Delete	Allow	403	403	404

Why return 404 to outsiders? It avoids revealing whether a private document exists.

5. Trace: Bob tries to edit Alice's document

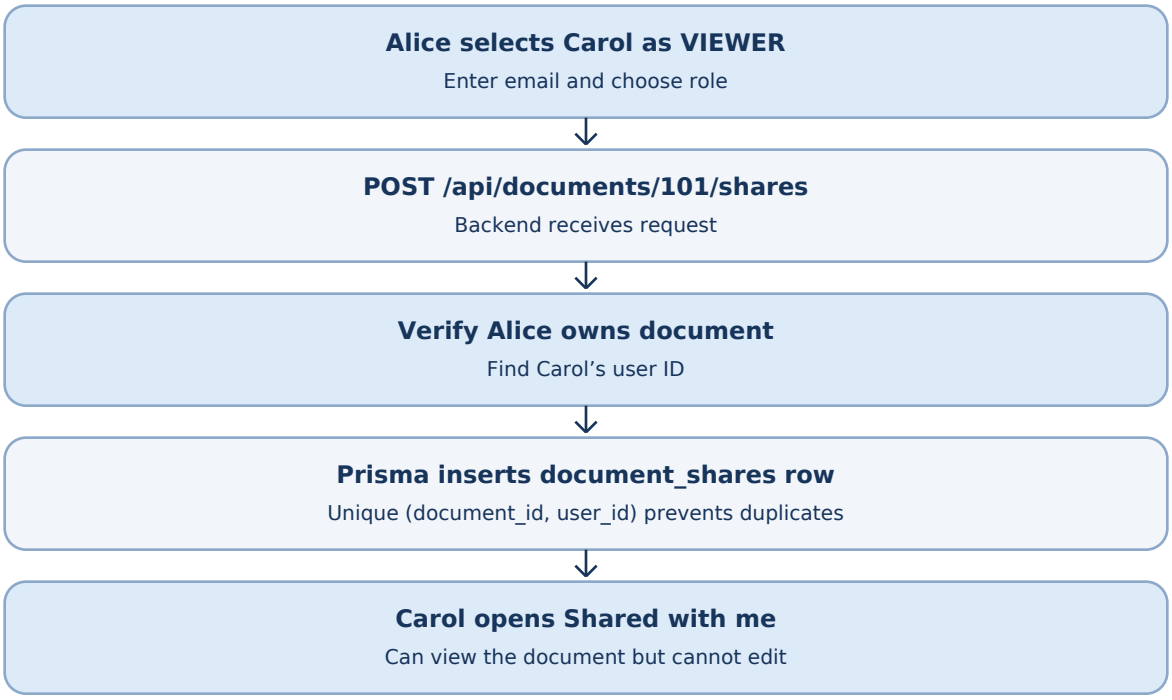


Example authorization query:

```
SELECT 1
FROM documents d
LEFT JOIN document_shares s
  ON s.document_id = d.id
  AND s.user_id = $2
WHERE d.id = $1
  AND (
    d.owner_id = $2
    OR s.role = 'EDITOR'
  );
```

For stronger race-condition protection, I enforce the permission condition in the actual UPDATE, not only in a preceding SELECT.

6. Trace: Alice shares a document with Carol



7. What happens when a request is forbidden?

Scenario	HTTP response
No valid session	401 Unauthorized
Bob (viewer) tries editing	403 Forbidden
Carol has no access	404 Not Found
Document doesn't exist	404 Not Found
Invalid request body	400 Bad Request

Important: Hiding the Edit button in React is not security. Someone can manually send HTTP requests. The backend must check permissions on every protected operation.

Next topic: Document editing ? how TipTap manages editor state, how rich-text formatting becomes JSON, and how I persist and restore it.